UNIVERSITY OF ST. LA SALLE

IT Helpdesk

COMPANION TO LE-IAS · SECURE LOGIN SYSTEM

Verification Notes and Guide

How the system was checked, what was found and fixed, and how to set up, test and demonstrate it

GROUP MEMBERS

Parcon, Rayle

Paza, Ezra Joie

Punzalan, Khirk Justin

Plateros, Glory Mae

RESULT

149 of 149 security checks passing

64 of 64 browser checks passing

Both suites passed three runs in a row

22 defects found and fixed

October 21, 2026

RELIGIO · MORES · CULTURA

1. Verification Summary

After the system was rebuilt, it was checked three independent ways so that no single method's blind spots could hide a problem:

Method	What it covered
Security code review	Every server-side file was read line by line looking for weaknesses in sign-in, sessions, two-factor, access control, input handling, cryptography and the audit log.
Front-end code review	Every template, the stylesheet and the JavaScript were checked for broken behaviour, blocked code, layout problems on phones and accessibility issues.
Real-browser testing	A script drove Microsoft Edge through every page as each role: registering, signing in with two-factor codes, filing and withdrawing tickets, using filters, menus and confirmation dialogs, and following every link, on desktop and phone screen sizes.
Automated security suite	`tests/run.php` attacks a throwaway copy of the system over real HTTP and inspects the database afterwards. New tests were added for every defect found by the reviews.

149 / 149 security checks passed, three runs in a row.
The browser test passed 64 / 64 checks, three runs in a row, with no broken links, error pages or console errors.

Why three runs? Some checks depend on timing (session timeouts, two-factor time windows, response-time comparisons). Passing the same checks three times in a row shows the results are stable and not the product of lucky timing.

2. Security Defects Found and Fixed

Each defect below was confirmed against the code before it was fixed, and each now has its own automated test.

Severity	Problem	Fix
High	Someone who knew a password could open many half-finished sign-ins and keep guessing two-factor codes in each of them after the account locked.	The lockout is checked before any code is tried, so extra sessions give no extra guesses.
Medium	Unknown usernames took about twice as long to reject as wrong passwords, revealing which accounts exist.	Unknown users are checked against a fixed hash with identical cost settings. A test now measures that both take the same time.
Medium	Password checks on the Security settings page had no limit on wrong guesses.	All of them use the same rate-limited check as step-up authentication; after 5 wrong guesses the session ends.
Medium	Two-factor could be turned on or replaced without the password, letting a hijacked session enrol the attacker's own phone.	Setup requires the password and is refused while two-factor is already on.
Medium	One student's failed sign-ins could lock out everyone sharing the campus's public IP address.	The per-address limit was raised from 20 to 50 failures, which still stops password spraying.
Medium	Very long or invalid UTF-8 usernames could cause an error page or make the audit log look tampered with.	Input is cleaned and cut to the column size before it is stored.
Medium	The two-factor lockout missed failures that happened in the same second as a correct password.	Failures are counted by record order instead of one-second timestamps.
Low	A half-finished two-factor sign-in survived a password change for up to 5 minutes.	Pending sign-ins remember the session version and browser, and are cancelled when either changes.
Low	Two requests arriving at the same moment could both use one authenticator code or recovery code.	Codes are claimed with a single atomic database update.
Low	A deactivated account was told it was deactivated, which confirmed the password was correct.	It now receives the same generic error as a wrong password.
Low	The admin setup script could reset and promote a different account if the e-mail was already in use.	It looks accounts up by username only and refuses e-mail conflicts.
Low	Simultaneous audit-log writes could, in rare cases, break the integrity chain.	Writers now take a database lock, so entries are always chained in order.

3. Front-End Defects Found and Fixed

Problem	Fix
Typing in the "My tickets" search box hid nothing: the layout style overrode the hidden state.	A global rule keeps hidden items hidden. The browser test now checks what is actually visible on screen.
Pressing Enter in a search box reloaded the page and cleared the search.	Enter no longer submits the search box.
The user filter matched almost every row, because it also searched the role menus and button labels.	Each row carries clean search text: name, e-mail, role and status.
The password strength meter could call a password "Strong" that the server would reject, and showed "Fair" for 4-character passwords.	The meter now follows the server rules exactly and reads the minimum length from the configuration.
Footer links on the landing page sent signed-in staff to an "Access denied" page.	The footer shows links that match the viewer's role.
Pasting a code shown as "123 456" lost the last digit.	The code box accepts the pasted text and keeps all six digits.
Resolving the only ticket on the last page left an empty list with no way back.	The queue and audit log move to the new last page automatically.
Filter buttons stayed disabled after using the browser's Back button.	Buttons are re-enabled when a page is restored, and filter buttons are never locked.
The hidden mobile menu could still be reached with the Tab key.	The closed menu is removed from keyboard focus; opening it moves focus inside.
The landing-page preview was squeezed into a narrow column on phones.	The phone layout rule now takes priority.
The registration form skipped the browser's own checks (pattern, length, matching passwords).	Browser checks are on, so mistakes show before the form is sent. The server still checks everything.

Unused styles left over from earlier designs were also removed.

4. Changes Users Will Notice

- **Setting up two-factor asks for the password first.** This stops anyone using an unattended computer from linking their own phone to the account.
- **A deactivated account sees "Incorrect username or password."** instead of a "deactivated" message, so the response never confirms a password. Users who are locked out this way should contact IT Services.
- **Wrong guesses on the Security settings page are limited.** After 5 wrong current passwords, the user is signed out.

5. Suggestions Reviewed but Not Applied

The review also raised the lower-risk ideas below. Each was weighed and deliberately left for later, because the cost or risk of the change outweighs the benefit for this project.

Suggestion	Why it was not applied now
Use separate keys for encryption and for the audit-log signature, and bind each two-factor secret to its user.	Every stored two-factor secret would need re-encrypting and the whole audit chain rebuilding. The current single key is never stored in the database, which already protects both.
Lock the "last administrator" check inside a database transaction.	The problem needs two administrators to deactivate each other in the same instant. It would be a real fix for a large organisation; for this helpdesk the setup script can always restore an administrator.
Reduce the processing cost of checking recovery codes.	Each attempt checks up to 8 hashes, but the lockout already allows only 5 attempts per 15 minutes, which caps the cost.
Hide whether a username is already taken during registration.	Telling new users their name is taken is necessary for usability. Registration is limited to 5 accounts per hour per network address, which limits probing.
Hide the password while typing it into the admin setup script.	Windows terminals offer no simple portable way to do this. The script accepts the password through an environment variable instead.

6. Guide: Setting Up the System

1. Copy the project folder into `C:\xampp\htdocs\`, for example as `C:\xampp\htdocs\helpdesk`.
2. Start **Apache** and **MySQL** in the XAMPP Control Panel.
3. Open phpMyAdmin, choose **Import**, select `database/schema.sql` and press **Go**. A database from the first version is upgraded in place without losing data.
4. Create the first administrator in a terminal:

   ```
   cd C:\xampp\htdocs\helpdesk
   C:\xampp\php\php.exe setup\create_admin.php
   ```

5. Open `http://localhost/helpdesk/` in the browser and sign in.

Keep `config/secrets.php` private. It is created on first use and holds the keys that protect passwords and two-factor secrets. It is excluded from Git. If it is lost, every password must be reset.

7. Guide: Running the Security Tests

```
C:\xampp\php\php.exe tests\run.php
```

- The suite builds its own throwaway database (`secure_system_test`) and its own web server, so real data is never touched.
- It takes about 75 seconds, because some checks wait for timeouts to expire on purpose.
- Each check prints PASS or FAIL, followed by a summary line. Any failure gives a non-zero exit code.
- If XAMPP's MySQL uses a password or a different port, set `DB_USER`, `DB_PASS` or `DB_PORT` before running.

8. Guide: Demonstrating the System

A suggested order for the presentation, each step showing one control from the report:

#	Do this	What it shows
1	Run `php tests\run.php`	All 149 checks passing
2	Register with the password `password123`, then with a strong one	Server-side password policy and the live strength meter
3	Enter a wrong password 5 times, then the right one; repeat with a made-up username	Brute-force lockout with identical behaviour for unknown accounts
4	In phpMyAdmin, open the `users` table	Passwords stored as `$argon2id$...` hashes, never plain text
5	Security settings: set up two-factor with Google or Microsoft Authenticator, sign out, sign back in	Two-factor sign-in, recovery codes shown once
6	As a student, type `admin_tickets.php` into the address bar	Role-based access control: "Access denied", recorded in the audit log
7	As admin, change a signed-in student's role, then click anything as the student	Role changes take effect immediately; the student is signed out
8	File a ticket with `<script>alert(1)</script>` as the subject	The script appears as plain text and never runs
9	In phpMyAdmin, edit any row of `audit_log`, then press *Verify integrity*	The tamper-evident log reports exactly which entry was changed

Tip: step 3 locks the account for 15 minutes. Do it with a spare account, or clear the lock afterwards from *Users* with the *Unlock* action.